

BUG REPORT — HW06 API Testing

SV Ninh Van Khai — 23127060 | SUT: EShop @ 85af3ba | De bai muc 6.5

Moi bug trong tai lieu nay deu **tai hien duoc bang request that**. Phan `curl` va phan response o tung muc duoc trích thàng từ `bugs/evidence/<ID>.md` — là kết quả của một lần chạy `that` bằng `scripts/capture_bug_evidence.py`, không gõ tay.

Chạy lại toàn bộ bằng chung:

```
python scripts/capture_bug_evidence.py --base http://localhost:3000 --out bugs/evidence --sut-dir ../../../../eshop-sut/backend
```

1. Bảng tổng hợp

ID	Mức độ	Tiêu đề	API	Vi phạm	Bảng chứng	GitHub Issue
A-01	Critical	POST <code>/api/forgot-password</code> trả thàng ma OTP trong response body	API-1	SEC-07, FR-03	A-01.md (evidence/A-01.md)	<dien link>
A-07	Critical	Mat khau lưu plaintext và bị trả về trong response của <code>login/users/me</code>	API-1	SEC-01	A-07.md (evidence/A-07.md)	<dien link>
B-01	Critical	<code>checkout</code> tin tuyệt đối <code>total_amount</code> do client gửi	API-2	FR-08	B-01.md (evidence/B-01.md)	<dien link>
B-01b	Critical	<code>checkout</code> chấp nhận <code>total_amount</code> am	API-2	FR-08	B-01b.md (evidence/B-01b.md)	<dien link>
B-02	Critical	GET <code>/api/orders/:id</code> thiếu hạn xác thực - IDOR	API-2	SEC-02	B-02.md (evidence/B-02.md)	<dien link>
B-03	Critical	PUT <code>/api/admin/orders/:id/status</code> không kiểm tra <code>role</code>	API-2	SEC-03, FR-12	B-03.md (evidence/B-03.md)	<dien link>
B-05	Critical	Cong thức giảm giá <code>percent</code> sai dấu, cho ra số tiền giảm AM	API-2	FR-09	B-05.md (evidence/B-05.md)	<dien link>
B-07	Critical	<code>apply-coupon</code> không xác thực; bỏ <code>user_id</code> là bỏ qua toàn bộ kiểm tra hạn mức	API-2	SEC-02, FR-09	B-07.md (evidence/B-07.md)	<dien link>
C-01	Critical	POST / PUT / DELETE <code>/api/products</code> hoàn toàn không xác thực	API-3	SEC-02, SEC-03, FR-12	C-01.md (evidence/C-01.md)	<dien link>

C-02	● Critical	SQL Injection qua tham so <code>?search=</code>	API-3	SEC-05	C-02.md (evidence/ C-02.md)	<dien link>
C-13	● Critical	Mot san pham co <code>price = null</code> lam SAP HAN backend khi doc lai (tu choi dich vu)	API-3	FR-15	C-13.md (evidence/ C-13.md)	<dien link>
X-01	● Critical	PUT <code>/api/users/me</code> cho phep user thuong tu nang <code>role</code> len <code>admin</code>	lien API	SEC-06, FR-04, FR-12	X-01.md (evidence/ X-01.md)	<dien link>
A-02	● High	OTP chi co 4 chu so trong khi dac ta doi toi thieu 6	API-1	SEC-07, FR-03	A-02.md (evidence/ A-02.md)	<dien link>
A-03	● High	User enumeration qua ma trang thai cua <code>forgot-password</code>	API-1	FR-03	A-03.md (evidence/ A-03.md)	<dien link>
A-05	● High	<code>reset-password</code> khong kiem tra do manh mat khau	API-1	FR-01, FR-03	A-05.md (evidence/ A-05.md)	<dien link>
A-09	● High	Bo dem dang nhap sai cong +2 moi lan nen tai khoan bi khoa o lan sai thu HAI	API-1	FR-02	A-09.md (evidence/ A-09.md)	<dien link>
B-06	● High	Nguong don toi thieu dung <code>></code> thay vi <code>>=</code>	API-2	FR-09	B-06.md (evidence/ B-06.md)	<dien link>
B-09	● High	PUT <code>/api/orders/:id/cancel</code> cho phep huy don dang giao (<code>shipping</code>)	API-2	FR-10	B-09.md (evidence/ B-09.md)	<dien link>
B-10	● High	<code>admin/orders/:id/status</code> cho phep chuyen <code>canceled -> delivered</code>	API-2	FR-10	B-10.md (evidence/ B-10.md)	<dien link>
C-03	● High	Loi SQL tra ve HTML kem thông điệp của tang CSDL	API-3	SEC-05	C-03.md (evidence/ C-03.md)	<dien link>
C-04	● High	GET <code>/api/products/:id</code> voi id khong ton tai tra <code>200 {}</code> thay vi <code>404</code>	API-3	FR-15	C-04.md (evidence/ C-04.md)	<dien link>
C-05	● High	<code>price</code> la so voi id le nhung la chuoai voi id chan	API-3	FR-15	C-05.md (evidence/ C-05.md)	<dien link>
C-06	● High	POST <code>/api/products</code> khong validate bat ky truong nao	API-3	FR-15	C-06.md (evidence/ C-06.md)	<dien link>
A-08	● Medium	<code>forgot-password</code> bo qua bien loi cua <code>db.get</code> nen loi CSDL bi bao thanh 404	API-1	FR-03	A-08.md (evidence/ A-08.md)	<dien link>
B-08	● Medium	Kiem tra han su dung nam ben trong nhanh nguong don nen thông báo lỗi sai nguyên nhân	API-2	FR-09	B-08.md (evidence/ B-08.md)	<dien link>

B-11	● Medium	POST /api/coupon-usage ghi nhan luot dung cho coupon_id khong ton tai	API-2	FR-09	B-11.md (evidence/B-11.md)	<dien link>
B-12	● Medium	checkout tao duoc don hang khi thieu han shipping_address	API-2	FR-08	B-12.md (evidence/B-12.md)	<dien link>
C-07	● Medium	PUT /api/products/:id voi id khong ton tai van tra 200 Product updated	API-3	FR-15	C-07.md (evidence/C-07.md)	<dien link>
C-08	● Medium	DELETE /api/products/:id voi id khong ton tai van tra 200 Product deleted	API-3	FR-15	C-08.md (evidence/C-08.md)	<dien link>
C-09	● Medium	PUT khong ho tro cap nhat mot phan: truong khong gui bi ghi de thanh null	API-3	FR-15	C-09.md (evidence/C-09.md)	<dien link>
C-10	● Medium	category_id khong duoc kiem khoa ngoai	API-3	FR-15	C-10.md (evidence/C-10.md)	<dien link>
C-11	● Medium	name va description khong duoc sanitize - nguon cua stored XSS	API-3	SEC-04	C-11.md (evidence/C-11.md)	<dien link>
B-14	○ Low	checkout tra ve 200 thay vi 201 Created	API-2	FR-08	B-14.md (evidence/B-14.md)	<dien link>
C-12	○ Low	POST /api/products tra ve 200 thay vi 201 Created	API-3	FR-15	C-12.md (evidence/C-12.md)	<dien link>

Tong 34 bug: 12 Critical, 11 High, 9 Medium, 2 Low.

API	So bug
API-1	7
API-2	13
API-3	13
lien API	1

De bai doi toi thieu 3 bug that cho moi API; ca ba deu vuot xa nguong nay.

2. Chi tiet tung bug

A-01 — POST /api/forgot-password tra thang ma OTP trong response body

Muc do	● Critical
API	API-1
Vi pham	SEC-07, FR-03

Bang chung day du

bugs/evidence/A-01.md (evidence/A-01.md)

Anh huong: Bat ky ai biet dia chi email cua nan nhan deu chiem duoc tai khoan trong hai request, khong can truy cap hop thu. Day la duong chiem tai khoan ngan nhat trong toan he thong: goi forgot-password de lay OTP, roi goi reset-password de dat mat khau moi.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X POST 'http://localhost:3000/api/forgot-password' \
  -H 'Content-Type: application/json' \
  -H 'X-Student-Id: 23127000' \
  -d '{"email": "api@victim-23127000test.local"}
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "M\u00e0 d\u00f2t m\u00e0t kh\u00e1u \u00c1 \u00c1\u00dc\u00d2\u00c1\u00c1", "resetToken": "5555"}
```

Ket qua mong doi: theo eshop-sut/README.md (SEC-07, FR-03).

De xuat sua: Bo resetToken khoi response. Gui OTP qua email. Trong moi truong demo, ghi ra log may chu chu khong tra ve cho client.

A-07 — Mat khau luu plaintext va bi tra ve trong response cua login / users/me

Muc do	Critical		
API	API-1		
Vi pham	SEC-01		
Bang chung day du	bugs/evidence/A-07.md (evidence/A-07.md)		

Anh huong: Cot password luu nguyen van. SELECT * roi res.json(user) dua ca password lan reset_token ra ngoai. Bat ky ai xem duoc mot response login (log, proxy, cache trinh duyet) deu co mat khau that. Vi nguai dung thuong dung lai mat khau, thiet hai vuot ra ngoai he thong nay.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X GET 'http://localhost:3000/api/users/me' \
  -H 'Content-Type: application/json' \
  -H 'X-Student-Id: 23127000' \
  -H 'Authorization: Bearer token'
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id": 1, "name": "Victim", "email": "api@victim-23127000test.local", "password": "api@3d1", "resetToken": "5555"}
```

Ket qua mong doi: theo eshop-sut/README.md (SEC-01).

De xuat sua: Bam mat khau bang `bcrypt` khi ghi. Khi doc, chon dung cot can dung thay vi `SELECT *`, hoac loai bo `password` va `reset_token` truoc khi tra ve.

B-01 — `checkout` tin tuyet doi `total_amount` do client gui

Muc do	● Critical
API	API-2
Vi pham	FR-08
Bang chung day du	bugs/evidence/B-01.md (evidence/B-01.md)

Anh huong: SRS FR-08 ghi ro: "Backend phai tu tinh lai tong tien; khong chap nhan gia tri `total_amount` do client gui len". Thuc te gia tri duoc ghi thang vao bang `orders`. Mua duoc dien thoai 30 trieu voi gia 1 dong. Day la lo hong gay thiet hai tai chinh truc tiep.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X GET 'http://localhost:3000/api/orders'
-H 'Content-Type: application/json'
-H 'X-Student-Id: 23127060'
-H 'Authorization: Bearer <token>
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id":9,"user_id":9,"total_amount":1,"status":"pending","shipping_address":"1 1
doi","created_at":"2026-09-01 08:33:12"}
```

Ket qua mong doi: theo `eshop-sut/README.md` (FR-08).

De xuat sua: Bo `total_amount` khoi body. Tinh lai tu gio hang phia may chu: doc `userCarts[userId]`, tra cuu gia tung san pham trong bang `products`, roi cong lai.

B-01b — `checkout` chap nhan `total_amount` am

Muc do	● Critical
API	API-2
Vi pham	FR-08
Bang chung day du	bugs/evidence/B-01b.md (evidence/B-01b.md)

Anh huong: Truong hop rieng cua B-01 nhung dang chu y rieng: don hang co tong tien am duoc tao thanh cong. Neu he thong co buoc hoan tien hoac tinh doanh thu, so am se lam sai toan bo so sach.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X POST 'http://localhost:3000/api/checkout'
```

```
-H 'Content-Type: application/json'
-H 'X-Student-Id: 23127060'
-H 'Authorization: Bearer <token>'
-d '{"total_amount": -500000, "shipping_address": "I Le Loi"}
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "Checkout successful", "orderId": 10}
```

Ket qua mong doi: theo eshop-sut/README.md (FR-08).

De xuất sửa: Sau khi tu chỉnh lại tổng tiền phía máy chủ, thêm ràng buộc CHECK (`total_amount > 0`) ở tầng CSDL.

B-02 — GET /api/orders/:id thiếu hạn xác thực - IDOR

Mức độ	Critical
API	API-2
Vi phạm	SEC-02
Bang chứng đầy đủ	bugs/evidence/B-02.md (evidence/B-02.md)

Ảnh hưởng: Endpoint không có middleware `authenticateToken`. Bất kỳ ai duyệt lần lượt id từ 1 đều đọc được toàn bộ đơn hàng của mọi người dùng: địa chỉ giao hàng, tổng tiền, trạng thái. Đây là lỗ hổng dữ liệu cá nhân trên diện rộng.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -s -X GET 'http://localhost:3000/api/orders/1'
-H 'Content-Type: application/json'
-H 'X-Student-Id: 23127060'
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id": 1, "user_id": 1, "total_amount": 500000, "status": "pending", "shipping_address": "I Le Loi", "created_at": "2026-09-01 08:33:12"}
```

Ket qua mong doi: theo eshop-sut/README.md (SEC-02).

De xuất sửa: Thêm `authenticateToken` vào endpoint, và thêm điều kiện `AND user_id = ?` vào câu truy vấn để người dùng chỉ đọc được đơn của chính mình.

B-03 — PUT /api/admin/orders/:id/status không kiểm tra role

Mục do	● Critical
API	API-2
Vi phạm	SEC-03, FR-12
Bang chung day du	bugs/evidence/B-03.md (evidence/B-03.md)

Anh huong: Endpoint co `authenticateToken` nhưng khong he doc `req.user.role`. Bat ky nguoi dung dang nhap nao cung doi duoc trang thai don hang cua nguoi khac - vi du danh dau don cua nguoi khac la da giao de chan viec huy don.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X PUT 'http://localhost:3000/api/admin/orders/12/status' \
-H 'Content-Type: application/json' \
-H 'X-Student-Id: 23127060' \
-H 'Authorization: Bearer <token>' \
-d '{"status": "confirmed"}
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8
{"message": "Order status updated"}
```

Ket qua mong doi: theo `eshop-sut/README.md` (SEC-03, FR-12).

De xuat sua: Them middleware kiem quyen: `if (req.user.role !== 'admin') return res.status(403).json(...)` **Ap cho toan bo nhom duong dan** `/api/admin/*`

B-05 — Công thức giảm giá percent Sai đầu, cho ra số tiền giảm AM

Mục do	● Critical
API	API-2
Vi phạm	FR-09
Bang chung day du	bugs/evidence/B-05.md (evidence/B-05.md)

Anh huong: Code tinh `discount = Math.floor(total * (1 - discount_value))`. Voi `discount_value = 10` (nghia la 10%), cong thuc thanh `total * (1 - 10) = total * (-9)`. Voi don 500.000d, `discount_amount` la **-4.500.000** va `final_amount` thanh **5.000.000** - khach hang bi tinh gap muoi lan khi ap ma giam gia. SRS FR-09 ghi ro cong thuc dung la `total * discount_value / 100`.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X POST 'http://localhost:3000/api/apply-coupon' \
-H 'Content-Type: application/json' \
-H 'X-Student-Id: 23127060' \
-d '{"code": "SAVE10", "total_amount": 500000, "user_id": 11}'
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"success":true,"coupon_id":1,"discount_amount":1500000,"final_amount":5000000,"message":"\u0111\u00e0p \u0111\u00fang  
th\u00e0nh c\u00f4ng! Gi\u00e1m 10%!"}
```

Ket qua mong doi: theo eshop-sut/README.md (FR-09).

De xuất sửa: Sửa thành `Math.floor(total_amount * coupon.discount_value / 100)`.

B-07 — apply-coupon không xác thực; bỏ user_id là bỏ qua toàn bộ kiểm tra hạn mức

Mức độ	● Critical
API	API-2
Vi phạm	SEC-02, FR-09
Bang chứng đầy đủ	bugs/evidence/B-07.md (evidence/B-07.md)

Anh hưởng: Endpoint không có `authenticateToken` và lấy `user_id` từ body. Nghiêm trọng hơn: phép kiểm tra hạn mức nằm trong nhánh `if (user_id)`, **nen không gửi** trường này sẽ đi vào nhánh `else` và áp mã mà không đếm lượt nào cả. Đây là nghịch lý "bỏ bớt dữ liệu để được nhiều quyền hơn": mà giới hạn một lượt mỗi người trở thành dùng được vô hạn.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -X POST -H 'Host: localhost:3000' -H 'Content-Type: application/json' -d '{"X-Student-Id": "23127060", "code": "VIP100", "total_amount": 5000000}'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"success":true,"coupon_id":3,"discount_amount":100000,"final_amount":400000,"message":"\u0111\u00e0p \u0111\u00fang  
th\u00e0nh c\u00f4ng! Gi\u00e1m 100,000 d!"}
```

Ket qua mong doi: theo eshop-sut/README.md (SEC-02, FR-09).

De xuất sửa: Thêm `authenticateToken` và lấy `user_id` từ `req.user.id`, không bao giờ từ body. Bỏ hoàn toàn nhánh `else`.

C-01 — POST / PUT / DELETE /api/products hoàn toàn không xác thực

Mức độ	● Critical
API	API-3
Vi phạm	SEC-02, SEC-03, FR-12

Bang chung day du	bugs/evidence/C-01.md (evidence/C-01.md)
-------------------	--

Anh huong: SRS FR-12 liet ke dich danh ba endpoint nay trong nhom bat buoc phai co token JWT hop le va role = 'admin'. Thuc te khong co middleware nao ca. Mot nguoi hoan toan khong dang nhap co the xoa sach toan bo catalog san pham, hoac sua gia moi mat hang ve 0. Day la bug nghiêm trọng nhất của API-3.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X DELETE 'http://localhost:3000/api/products/14' \
-H 'Content-Type: application/json' \
-H 'X-Student-Id: 23127060'
```

Ket qua thuc te:

```
HTTP/1.1 204
Content-Type: application/json; charset=utf-8
{
  "message": "Product deleted"
}
```

Ket qua mong doi: theo eshop-sut/README.md (SEC 02, SEC 03, FR 12).

De xuat sua: Them authenticateToken va middleware kiem role === 'admin' cho ca ba endpoint.

C-02 — SQL Injection qua tham so ?search=

Muc do	● Critical
API	API-3
Vi pham	SEC-05
Bang chung day du	bugs/evidence/C-02.md (evidence/C-02.md)

Anh huong: Cau truy van duoc noi chui truc tiep. WHERE name LIKE '%\$\${searchQuery}%'. Payload '%' OR '1'='1 tra ve toan bo bang. Nghiêm trọng hơn, payload UNION SELECT doc duoc bang users: lan chay thu nghiem tra ve nguoi van admin@eshop.com kem mat khau Admin123! trong truong price. Ket hop voi A-07 (mat khau luu plaintext), mot request duy nhat lay duoc thong tin dang nhap cua quan tri vien.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X GET 'http://localhost:3000/api/products?search=%25%27%20UNION%20SELECT%20id%2Cemail%2Cpassword%2Crole%2C1%2C1%20FROM%20users--%20' \
-H 'Content-Type: application/json' \
-H 'X-Student-Id: 23127060'
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8
[{"id":1,"name":"admin@eshop.com","price":"Admin123!","description":"admin","imageUrl":1,"category_id":1}, {"id":1,"name":"iPhone 15 Pro Max","price":30000000,"description":"Điện thoại cao cấp của Apple","imageUrl":"https://placeholder.co/300x300/png?text=iPhone15","category_id":1}, {"id":2,"name":"Samsung Galaxy S24 Ultra","price":28000000,"description":"Màn hình hiển thị xuất sắc, camera siêu zoom","imageUrl":"https://placeholder.co/300x300/png?text=SamsungS24","category_id":1}]
```

```
"id":3,"name":"MacBook Pro M3","price":45000000,"description":"laptop chuyên nghiệp mạnh mẽ","imageUrl":"https://placeholder.co/300x300/png?text=Macbook+Pro","category_id":2},
{"id":3,"name":"api.a01.victim.23127060test.local","price":"Api1234!","description":"user","imageUrl":"https://placeholder.co/300x300/png?text=Api+Prod+Prod","category_id":1},
{"id":3,"name":"Tai nghe AirPods Pro 2","price":6000000,"description":"Chống ồn chủ động xuất sắc","imageUrl":"https://placeholder.co/300x300/png?text=Api+Prod+Prod","category_id":1},
{"id":4,"name":"api.a02.victim.23127060test.local","price":"Api1234!","description":"","imageUrl":"https://placeholder.co/300x300/png?text=Api+Prod+Prod","category_id":1},
{"id":5,"name":"BA",
  "price":100000000,
  "description":null,
  "imageUrl":null,
  "category_id":1},
{"id":6,"name":"BA",
  "price":100000000,
  "description":null,
  "imageUrl":null,
  "category_id":1}
```

Ket qua mong doi: theo eshop-sut/README.md (SEC-05).

De xuất sửa: Dung tham so hoa: `db.all("SELECT * FROM products WHERE name LIKE ?", ['%' + searchQuery + '%'], ...)`. Day dung la dieu SEC-05 yeu cau.

C-13 — Mot san pham co `price = null` lam SAP HAN backend khi doc lai (tu choi dich vu)

Muc do	Critical				
API	API-3				
Vi pham	FR-15				
Bang chung day du	bugs/evidence/C-13.md (evidence/C-13.md)				

Anh huong: Day la bug nguy hiem nhat tim duoc, va no la **he qua day chuyen cua hai bug khac**. C-09 cho phép mot lenh `PUT` thieu truong ghi de `price` thanh `null`. Sau do, C-05 chay `row.price.toString()` tren gia tri `null` khi id la so chan. `TypeError` nem ra trong callback cua `sqlite3` khong duoc ai bat. Node thoat han, **toan bo API ngung phuc vu**. Trong lan chay thu nghiem, request tiep theo tra ve `Connection refused` va moi kick ban sau do khong chay duoc nua. Mot nguoi khong dang nhap co the ha guc toan bo he thong bang **hai** request (C-01 cho phép goi `PUT` ma khong can token). Khong bug nao trong ba bug thanh phan tu no gay sap; chi to hop cua chung moi gay.

Buoc tai hien (buoc cuoi cua kick ban; cac buoc chuan bi xem file bang chung):

```
curl -X GET 'http://localhost:3000/api/products' \
  -H 'Content-Type: application/json' \
  -H 'X-Student-Id: 23127060'
```

Ket qua thuc te:

```
HTTP/1.1 0
Content-Type: text/html; charset=utf-8
Server: Node.js
Error: [Error: ECONNREFUSED] Connection refused
```

Ket qua mong doi: theo eshop-sut/README.md (FR-15).

De xuất sửa: Sua ca ba: (1) C-01 them xac thuc; (2) C-09 chi cap nhat truong duoc gui; (3) C-05 xoa dong ep kieu. Ngoai ra bat buoc phai co `process.on('uncaughtException')` va mot tang xu ly loi cho moi callback cua tang CSDL, de mot ban ghi hong khong the ha duoc ca tien trinh.

X-01 — `PUT /api/users/me` cho phép user thường tự nâng role lên `admin`

Mức độ	● Critical
API	lien API
Vi phạm	SEC-06, FR-04, FR-12
Bang chung day du	bugs/evidence/X-01.md (evidence/X-01.md)

Anh hưởng: Endpoint nhận trường `role` từ body và ghi thẳng vào CSDL. Bất kỳ tài khoản nào cung cấp trở thành admin bằng một request. Kết hợp với việc các API admin khác chỉ kiểm tra tồn tại của token, đây là đường leo thang quyền trơn tru.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bang chung):

```
curl -i -X GET 'http://localhost:3000/api/users/me' \
-H 'Content-Type: application/json' \
-H 'x-student-id: 23127000' \
-H 'Authorization: Bearer <token>'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id":1,"name":"Attacker","email":"api.xul.attacker.23127060@test.local","password":"Api1234!","role":"admin"}
```

Kết quả mong đợi: theo `eshop-sut/README.md` (SEC-06, FR-04, FR-12).

Đề xuất sửa: Bỏ `role` khỏi danh sách trường được phép cập nhật. Chỉ cho phép dùng ba trường `name`, `phone`, `shipping_address` như SRS FR-04 quy định.

A-02 — OTP chỉ có 4 chữ số trong khi đặc tả đòi tối thiểu 6

Mức độ	● High
API	API-1
Vi phạm	SEC-07, FR-03
Bang chung day du	bugs/evidence/A-02.md (evidence/A-02.md)

Anh hưởng: Không gian mã chỉ 9000 giá trị (1000-9999). Không có giới hạn số lần thử nên dù hết toàn bộ không gian là khả thi. Nghiêm trọng hơn: với 4 chữ số, chỉ cần khoảng 100 người cùng đăng ký reset là xác suất có hai người trùng mã vượt 40% (nghịch lý ngày sinh) - khi đó điều kiện `email AND reset_token` không còn bảo vệ được ai.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bang chung):

```
curl -i -X POST 'http://localhost:3000/api/forget-password' \
-H 'Content-Type: application/json' \
-H 'x-student-id: 23127000' \
-H '{"email": "api.a02.victim.23127000@test.local"}'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "M\u00e1 d\u00e1t l\u00e0i m\u00e1t kh\u00f3a \u0111\u00e3 \u0111\u00f9c t\u00e1o", "resetToken": "2289"}
```

Ket qua mong doi: theo eshop-sut/README.md (SEC-07, FR-03).

De xuất sửa: `Math.floor(100000 + Math.random() * 900000)` cho 6 chu so, va tot hon la dung `crypto.randomInt` thay vi `Math.random` (khong an toan ve mat mat ma).

A-03 — User enumeration qua ma trang thai cua forgot-password

Muc do	● High
API	API-1
Vi pham	FR-03
Bang chung day du	bugs/evidence/A-03.md (evidence/A-03.md)

Anh hưởng: Email không tồn tại trả 404, email tồn tại trả 200. Kẻ tấn công có được toàn bộ danh sách người dùng của hệ thống chỉ bằng cách thử lần lượt các địa chỉ email.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chung):

```
curl -X POST 'http://localhost:3000/api/forgot-password' \
  -H 'Content-Type: application/json' \
  -H 'X-Student-Id: 23127060' \
  -d '{"email": "b@ronetwice.com", "password": "123456789"}'
```

Ket qua thuc te:

```
HTTP/1.1 404
Content-Type: application/json; charset=utf-8

{"error": "User not found"}
```

Ket qua mong doi: theo eshop-sut/README.md (FR-03).

De xuất sửa: Luôn trả về 200 với cùng một thông điệp chung chung, bất kể email có tồn tại hay không.

A-05 — reset-password không kiểm tra độ mạnh mật khẩu

Muc do	● High
API	API-1
Vi pham	FR-01, FR-03
Bang chung day du	bugs/evidence/A-05.md (evidence/A-05.md)

Anh hưởng: SRS đòi mật khẩu tối thiểu 8 ký tự, có chữ hoa, chữ thường, chữ số và ký tự đặc biệt. Thực tế chấp nhận cả chuỗi một ký tự "1". Người dùng đi qua luồng quên mật khẩu sẽ đặt được một mật khẩu mà

luong dang ky khong bao gio cho phep.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X POST 'http://localhost:3000/api/login'
-H 'Content-Type: application/json' \
-H 'X-Student-id: 23127060' \
-d '{"email": "api.a05.victim.23127060@test.local", "password": "1"}'
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "Login
successful", "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZiI6ImNwcm9sS2S16inVz2ZXIiLCJpYXQiOiJlB30DgyNjE",
"uid": "id", "name": "Victim", "email": "api.a05.victim.23127060@test.local", "password": "1", "role": "user", "login":
```

Ket qua mong doi: theo eshop-sut/README.md (FR-01, FR-03).

De xuat sua: Tach phepkiem do manh mat khau thanh mot ham dung chung, goi o ca register lan reset-password.

A-09 — Bo dem dang nhap sai cong +2 moi lan nen tai khoan bi khoa o lan sai thu HAI

Muc do	● High
API	API-1
Vi pham	FR-02
Bang chung day du	bugs/evidence/A-09.md (evidence/A-09.md)

Anh huong: SRS quy dinh khoa tu lan sai thu ba va khoa 30 giay. Thuc te: user.login_attempts + 2, nen dat nguoi 3 ngay o lan sai thu hai, va thoi gian khoa la 180000 ms = 180 giay, gap sau lan quy dinh. Ngoai dung go nham mat khau hai lan bi khoa ba phut.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X POST 'http://localhost:3000/api/login'
-H 'Content-Type: application/json' \
-H 'X-Student-id: 23127060' \
-d '{"email": "api.a05.victim.23127060@test.local", "password": "Api1234!@#"}'
```

Ket qua thuc te:

```
HTTP/1.1 401
Content-Type: application/json; charset=utf-8

{"error": "Tai khoan da bi khoa. Vui long thoi lai sau."}
```

Ket qua mong doi: theo eshop-sut/README.md (FR-02).

De xuat sua: Doi + 2 thanh + 1 va 180000 thanh 30000.

B-06 — Nguong don toi thieu dung > thay vi >=

Muc do	● High
API	API-2
Vi pham	FR-09
Bang chung day du	bugs/evidence/B-06.md (evidence/B-06.md)

Anh huong: SRS FR-09 dieu kien C3 ghi ro "Tong don hang >= (lon hon hoac bang) `min_order_amount`". Code viet `if (total_amount > coupon.min_order_amount)`. Don co gia tri bang dung nguong bi tu choi. Day la loi bien kinh dien, va no roi dung vao truong hop nguoi dung hay gap nhat: mua vua du nguong de duoc giam gia.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -X POST 'http://localhost:3000/api/apply-coupon'  
-H 'Content-Type: application/json'  
-H 'X-Student-Id: 23127060'  
-d '{"code": "SAVE10", "total amount": 300001, "user_id": 1}'
```

Ket qua thuc te:

```
HTTP/1.1 200  
Content-Type: application/json; charset=utf-8  
  
{"success":true,"coupon_id":1,"discount amount":-2700009,"final amount":3000010,"message":"Ap dụng thành công! Giảm 10%!"}
```

Ket qua mong doi: theo `eshop-sut/README.md` (FR-09).

De xuat sua: `Doi > thanh >=`.

B-09 — `PUT /api/orders/:id/cancel` cho phép huy don dang giao (shipping)

Muc do	● High
API	API-2
Vi pham	FR-10
Bang chung day du	bugs/evidence/B-09.md (evidence/B-09.md)

Anh huong: SRS FR-10 ghi ro: "Khi don hang da o trang thai `shipping`, User khong duoc phép tu huy - chi Admin moi co the thao tac". Code chi chan `delivered` va `canceled`. Khách hàng huy don khi hàng đang trên đường giao, gây thất thoát hàng và chi phí vận chuyển. Chính comment trong mã nguồn cũng thừa nhận điều kiện này sai.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -X PUT 'http://localhost:3000/api/orders/1'  
-H 'Content-Type: application/json'  
-H 'X-Student-Id: 23127060'
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id":13,"user_id":14,"total_amount":2500000,"status":"canceled","shipping_address":{"id":14,"created_at":"2026-03-01 00:33:33"}}
```

Ket qua mong doi: theo eshop-sut/README.md (FR-10).

De xuất sửa: Đổi điều kiện thành `if (order.status !== 'pending' && order.status !== 'confirmed')` dung nhu comment trong ma nguồn đã ghi.

B-10 — admin/orders/:id/status cho phép chuyển canceled -> delivered	
Mức độ	● High
API	API-2
Vi phạm	FR-10
Bảng chứng đầy đủ	bugs/evidence/B-10.md (evidence/B-10.md)

Anh hưởng: SRS FR-10 ghi rõ `delivered` và `canceled` là **trạng thái kết thúc**, không được chuyển sang bất kỳ trạng thái nào khác. Trong mã nguồn có một dòng riêng biệt `if (currentStatus === 'canceled' && status === 'delivered') isValidTransition = true` - một đơn đã hủy có thể bị đánh dấu là đã giao.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bảng chứng):

```
curl -i -X GET 'http://localhost:3000/api/orders/14'
Content-Type: application/json
{"id":14,"user_id":15,"total_amount":1500000,"status":"delivered","shipping_address":{"id":14,"created_at":"2026-03-01 00:33:33"}}
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id":14,"user_id":15,"total_amount":1500000,"status":"delivered","shipping_address":{"id":14,"created_at":"2026-03-01 00:33:33"}}
```

Ket qua mong doi: theo eshop-sut/README.md (FR-10).

De xuất sửa: Xóa dòng đó. Tốt hơn: thay chuỗi `if` bằng một bảng chuyển trạng thái khai báo được, để so sánh FR-10 và mã nguồn đọc ra cùng một thứ.

C-03 — Lỗi SQL trả về HTML kém thông điệp của tầng CSDL

Mức độ	● High
API	API-3
Vi phạm	SEC-05

Bang chung day du	bugs/evidence/C-03.md (evidence/C-03.md)
-------------------	--

Anh huong: Khi truy van loi, may chu tra `res.status(500).send('<h1>Database Error</h1><p>' + err.message + '</p>')` voi `Content-Type: text/html`. Hai hau qua: lo cau truc GSDL cho ke tan cong (giup tinh chinh payload SQLi), va pha vo hop dong JSON khi client goi `response.json()` bi nem loi.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X GET 'http://localhost:3000/api/products?search=%27' \
-H 'Content-Type: application/json' \
-H 'X-Student-Id: 23127060'
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: text/html; charset=utf-8

<h1>Database Error</h1><p>xxSQLi: ERROR: unrecognized token: "xx"</p>
```

Ket qua mong doi: theo `eshop-sut/README.md` (SEC-05).

De xuat sua: Tra ve `res.status(500).json({ error: 'Internal server error' })`. Ghi `err.message` vao log may chu, khong gui cho client.

C-04 — GET /api/products/:id voi id khong ton tai tra 200 {} thay vi 404	
Muc do	● High
API	API-3
Vi pham	FR-15
Bang chung day du	bugs/evidence/C-04.md (evidence/C-04.md)

Anh huong: Dong `if (!row) return res.status(200).json({})` tra ve thanh cong cho mot tai nguyen khong ton tai. Client khong phan biet duoc "khong tim thay" voi "tim thay nhung rong", va lop hien thi se ve ra mot san pham trong thay vi bao loi.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X GET 'http://localhost:3000/api/products/999999' \
-H 'Content-Type: application/json' \
-H 'X-Student-Id: 23127060'
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id": 999999, "name": "Product 999999", "price": 1000000}
```

Ket qua mong doi: theo `eshop-sut/README.md` (FR-15).

De xuất sua: `return res.status(404).json({ error: 'Product not found' });`

C-05 — `price` là số voi id lẻ nhưng là chuỗi voi id chẵn

Mức độ	● High
API	API-3
Vi phạm	FR-15
Bang chung day du	bugs/evidence/C-05.md (evidence/C-05.md)

Anh huong: Dong `if (row.id % 2 === 0) row.price = row.price.toString()` doi kieu du lieu theo tinh chẵn lẻ của khoa chính. Client công tiến sẽ nhận `"28000000" + 1000` ra chuỗi `"280000001000"`. Bug chỉ lộ ra khi so sánh hai response voi nhau; test riêng từng response đều thay hợp lệ.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bang chung):

```
curl -i -X GET 'http://localhost:3000/api/products/2' \
  -H 'Content-Type: application/json' \
  --data '{"id":2,"name":"Samsung Galaxy S24 Ultra","price":28000000,"description":"Màn hình hiển thị xuất
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=UTF-8

{"id":2,"name":"Samsung Galaxy S24 Ultra","price":"28000000","description":"Màn hình hiển thị xuất
độp, màn hình siêu 200Hz","imageurl":"http://placehold.co/600x600/png?text=samsungs24","category_id":1}
```

Kết quả mong doi: theo `eshop-sut/README.md` (FR-15).

De xuất sua: Xóa dòng đó. Thêm ràng buộc kiểu vào hợp đồng API và kiểm bang JSON Schema trong bộ test hồi quy.

C-06 — `POST /api/products` không validate bất kỳ trường nào

Mức độ	● High
API	API-3
Vi phạm	FR-15
Bang chung day du	bugs/evidence/C-06.md (evidence/C-06.md)

Anh huong: SRS FR-15 doi: tên bắt buộc tối đa 255 ký tự, giá bắt buộc và phải dương, danh mục bắt buộc chọn từ danh sách có sẵn. Thực tế tạo được sản phẩm với `price: -100`, `price: "abc"`, `name: null`. Dữ liệu không đi vào CSDL và gây hậu quả day chuyen - xem C-13.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bang chung):

```
curl -i -X POST 'http://localhost:3000/api/products'
```

```
-H 'Content-Type: application/json'
-H 'X-Student-Id: 23127060'
-d '{"name": null, "price": "abc", "description": "x", "imageUrl": "", "category_id": 1}'
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "Product created", "id": 161}
```

Ket qua mong doi: theo eshop-sut/README.md (FR-15).

De xuat sua: Them tang validate dau vao (vi du `express-validator` hoac mot hamkiem tay) truoc khi ghi.

A-08 — forgot-password bo qua bien loi cua db.get nen loi CSDL bi bao thanh 404

Muc do	● Medium
API	API-1
Vi pham	FR-03
Bang chung day du	bugs/evidence/A-08.md (evidence/A-08.md)

Anh huong: Callback nhan `(err, user)` nhung chi kiem `if (!user)`. Moi su co tang CSDL deu bien thanh "User not found", che mat su co that va lam nguoi dung tuong tai khoan cua ho khong ton tai.

Buoc tai hien (buoc cuoi cua kich ban, cac buoc chuan bi xem file bang chung):

```
curl -X POST -H 'Host: localhost:3000' -d '{"email": null}'
-H 'Content-Type: application/json'
-H 'X-Student-Id: 23127060'
-d '{"email": null}'
```

Ket qua thuc te:

```
HTTP/1.1 404
Content-Type: application/json; charset=utf-8

{"error": "User not found"}
```

Ket qua mong doi: theo eshop-sut/README.md (FR-03).

De xuat sua: Kiem `if (err) return res.status(500).json({ error: 'Internal error' })` truoc khi kiem `user`.

B-08 — Kiem tra han su dung nam ben trong nhanh nguong don nen thong bao loi sai nguyen nhan

Muc do	● Medium
--------	----------

API	API-2
Vi phạm	FR-09
Bang chung day du	bugs/evidence/B-08.md (evidence/B-08.md)

Anh huong: Phepkiem expired_at duoc long ben trong if (total_amount > min_order_amount). Mot ma da het han dung cho don nho hon nguong se bao "chua du gia tri toi thieu" thay vi "ma da het han". Nguoi dung se co mua them hang de dat nguong roi van bi tu choi.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X POST 'http://localhost:3000/api/apply-coupon' \
  -H 'Content-Type: application/json' \
  -H 'X-Student-Id: 23127060' \
  -d '{"code": "EXPIRED", "total_amount": 50000, "user_id": 1}'
```

Ket qua thuc te:

```
HTTP/1.1 400
Content-Type: application/json; charset=utf-8

{"error": "Don hang chua du gia tri toi thieu 100,000 d de ap dung ma nay"}
```

Ket qua mong doi: theo eshop-sut/README.md (FR-09).

De xuat sua: Tach nam dieu kien C1-C5 cua FR-09 thanh nam phepkiem doc lap, chay theo dung thu tu uu tien va moi phepkiem tra ve thong bao riêng.

B-11 — POST /api/coupon-usage ghi nhan luot dung cho coupon_id khong ton tai

Muc do	Medium
API	API-2
Vi phạm	FR-09
Bang chung day du	bugs/evidence/B-11.md (evidence/B-11.md)

Anh huong: Khongkiem tra ma giam gia co ton tai khong, cung khong gan voi don hang nao. Ke tan cong tao duoc ban ghi rac, hoac chen luot dung gia cho tai khoan nguoi khac de ho khong dung duoc ma nua.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X POST 'http://localhost:3000/api/coupon-usage' \
  -H 'Content-Type: application/json' \
  -H 'X-Student-Id: 23127060' \
  -H 'Authorization: Bearer <token>' \
  -d '{"coupon_id": 999999}'
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8
```

https://github.com/eshop-sut/README.md

Ket qua mong doi: theo eshop-sut/README.md (FR-09).

De xuat sua: Kiem coupon_id ton tai va gan ban ghi voi order_id that. Tot nhat la ghi nhan luot dung ngay trong giao dich thanh toan thay vi de client goi mot endpoint rieng.

B-12 — checkout tao duoc don hang khi thieu han shipping_address

Muc do	☐ Medium
API	API-2
Vi pham	FR-08
Bang chung day du	bugs/evidence/B-12.md (evidence/B-12.md)

Anh huong: Khong co phép kiểm nào. Đơn hàng được tạo với địa chỉ giao hàng null không thể giao được và chỉ phát hiện ra ở khâu vận hành.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bảng chung):

```
curl -i -X GET 'http://localhost:3000/api/orders/15'  
-H 'Content-Type: application/json'  
-H 'X-Student-Id: 23127060'
```

Ket qua thuc te:

```
HTTP/1.1 200  
Content-Type: application/json; charset=utf-8  
  
{"id":15,"user_id":17,"total_amount":100,"status":"pending","shipping_address":null,"created_at":"2026-03-18:33:12"}
```

Ket qua mong doi: theo eshop-sut/README.md (FR-08).

De xuat sua: Kiem shipping_address bat buoc va khong rong truoc khi ghi; hoac lay dia chi mac dinh tu ho so người dùng khi client không gửi.

C-07 — PUT /api/products/:id với id không tồn tại van tra 200 Product updated

Muc do	☐ Medium
API	API-3
Vi pham	FR-15
Bang chung day du	bugs/evidence/C-07.md (evidence/C-07.md)

Anh huong: Callback không đọc this.changes, nên không phân biệt được "đã cập nhật 1 dòng" với "không dòng nào khớp". Client tưởng đã lưu thành công trong khi không có gì thay đổi.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bảng chung):

```
curl -i -X PUT 'http://localhost:3000/api/products/999999'
-H 'Content-Type: application/json'
-H 'X-Student-Id: 23127060'
-d '{"name": "Khong Ton Tai", "price": 1, "description": "", "imageurl": "", "category_id": 1}
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "Product updated"}
```

Ket qua mong doi: theo eshop-sut/README.md (FR-15).

De xuất sửa: `if (this.changes === 0) return res.status(404).json({ error: 'Product not found' });`.

C-08 — DELETE /api/products/:id với id không tồn tại trả về 200 Product deleted

Mức độ	☒ Medium
API	API-3
Vi phạm	FR-15
Bảng chứng đầy đủ	bugs/evidence/C-08.md (evidence/C-08.md)

Ảnh hưởng: Cung nguyên nhân với C-07.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bảng chứng):

```
curl -i -X DELETE 'http://localhost:3000/api/products/999999'
-H 'Content-Type: application/json'
-H 'X-Student-Id: 23127060'
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "Product deleted"}
```

Ket qua mong doi: theo eshop-sut/README.md (FR-15).

De xuất sửa: Kiểm tra `this.changes` trước khi trả về thành công.

C-09 — PUT không hỗ trợ cập nhật một phần: trường không gửi bị ghi đè thành null

Mức độ	☒ Medium
API	API-3
Vi phạm	FR-15

Bang chung day du	bugs/evidence/C-09.md (evidence/C-09.md)
-------------------	--

Anh huong: Cau UPDATE products SET name=?, price=?, description=?, imageUrl=?, category_id=? luon ghi ca nam cot. Gui mot body chi co name se xoa trang bon trong con lai. Lan chay thu nghiem cho ket qua {"price": null, "description": null, "imageUrl": null, "category_id": null}. Day la nguyen nhan truc tiep cua C-13.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X GET 'http://localhost:3000/api/products/17'
-H 'Content-Type: application/json'
-H 'X-Student-id: 23127060'
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id":17,"name":"Chi doi tek","price":null,"description":null,"imageUrl":null,"category_id":null}
```

Ket qua mong doi: theo eshop-sut/README.md (FR-15).

De xuat sua: Dung cau UPDATE dong chi gom cac truong that su co mat trong body, hoac doi hoi PUT phai gui du va dung PATCH cho cap nhat mot phan.

C-10 — category_id không được kiểm khoa ngoài

Muc do	Medium
API	API-3
Vi pham	FR-15
Bang chung day du	bugs/evidence/C-10.md (evidence/C-10.md)

Anh huong: Tao duoc san pham voi category_id = 9999 trong khi bang categories chi co id 1, 2, 3. San pham tro toi mot danh muc khong ton tai va se khong hien ra o bat ky bo loc theo danh muc nao.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X GET 'http://localhost:3000/api/categories'
-H 'Content-Type: application/json'
-H 'X-Student-id: 23127060'
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

[{"id":1,"name":"Điện thoại"}, {"id":2,"name":"Laptop"}, {"id":3,"name":"Phụ kiện"}]
```

Ket qua mong doi: theo eshop-sut/README.md (FR-15).

De xuất sửa: Kiểm tra `category_id` tồn tại trước khi ghi, và khai báo `FOREIGN KEY (category_id) REFERENCES categories(id)` trong `database.js` kèm `PRAGMA foreign_keys = ON`.

C-11 — name và description không được sanitize - nguồn của stored XSS

Mức độ	● Medium
API	API-3
Vi phạm	SEC-04
Bảng chứng đầy đủ	bugs/evidence/C-11.md (evidence/C-11.md)

Anh hưởng: Payload `<script>` và `<img src=x onerror=>` được lưu nguyên văn vào CSDL và trả về nguyên văn. SEC-04 đòi dữ liệu người dùng nhập phải được escape khi hiển thị. **Giới hạn của phép kiểm tra:** ở tầng API chỉ chứng minh được **nguồn** - rằng máy chủ lưu payload thô. Việc nó có thực sự chạy trên trình duyệt hay không còn phụ thuộc vào lớp hiển thị, phải kiểm tra riêng ở tầng giao diện.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bảng chứng):

```
curl -i -X GET 'http://localhost:3000/api/products/19' \
  -H 'Content-Type: application/json' \
  --data '{"dependentId":23127060'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id":19,"name":"<script>alert('23127060')</script>","price":1000,"description":"<img src=x onerror=alert(1)>","imageurl":"","category_id":1}
```

Kết quả mong đợi: theo `eshop-sut/README.md` (SEC-04).

De xuất sửa: Escape khi hiển thị (không dùng `dangerouslySetInnerHTML`), và lọc đầu vào ngay ở tầng API như một lớp phòng thủ thứ hai.

B-14 — checkout trả về 200 thay vì 201 Created

Mức độ	○ Low
API	API-2
Vi phạm	FR-08
Bảng chứng đầy đủ	bugs/evidence/B-14.md (evidence/B-14.md)

Anh hưởng: Thao tác tạo tài nguyên mới phải trả `201 Created`. Không gây hại trực tiếp nhưng phá vỡ quy ước REST và làm client khó phân biệt "đã tạo" với "đã có sẵn".

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bảng chứng):

```
curl -i -X POST 'http://localhost:3000/api/checkout'
```

```
-H 'Content-Type: application/json'
-H 'X-Student-Id: 23127060'
-H 'Authorization: Bearer <token>'
-d '{"total amount": 500000, "shipping address": "I Le Loi"}
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "Checkout successful", "orderId": 16}
```

Ket qua mong doi: theo eshop-sut/README.md (FR-08).

De xuat sua: `res.status(201).json({ ... })`

C-12 — POST /api/products tra ve 200 thay vi 201 Created

Muc do	○ Low
API	API-3
Vi pham	FR-15
Bang chung day du	bugs/evidence/C-12.md (evidence/C-12.md)

Anh huong: Cung loai voi B-14.

Buoc tai hien (buoc cuoi cua kich ban; cac buoc chuan bi xem file bang chung):

```
curl -i -X POST 'http://localhost:3000/api/products'
-H 'Content-Type: application/json'
-H 'X-Student-Id: 23127060'
-d '{"name": "Ma trang thai 23127060", "price": 1000, "description": "x", "imageUrl": "", "category_id": 1}
```

Ket qua thuc te:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "Product created", "id": 21}
```

Ket qua mong doi: theo eshop-sut/README.md (FR-15).

De xuat sua: `res.status(201).json({ ... })`.

3. Cong viec con lai cua sinh vien (HUMAN H3)

De bai muc 6.5 doi moi bug phai duoc mo thanh mot GitHub Issue **kem anh chup man hinh**. Cac file trong bugs/ISSUE_TEMPLATES/ **da san sang de dan thang len GitHub**:

1. Mo <https://github.com/<tai-khoan>/<repo>/issues/new>.

2. Dan noi dung `bugs/ISSUE_TEMPLATES/<ID>.md` (dong dau la tieu de Issue).
3. Gan nhan theo muc do: `critical / high / medium / low`, kem nhan `api-1 / api-2 / api-3`.
4. Chup man hinh Issue vua tao, luu vao `bugs/screenshots/<ID>.png`.
5. Dien so hieu Issue vao cot **GitHub Issue** cua bang o muc 1.

Ưu tiên mở Issue cho 12 bug Critical trước nếu không đủ thời gian làm hết.